

Course Project: Part Two

Executive Summary

Ryan Verrot

Pikes Peak State College

CNG 2057 1N1: Network Defense and Countermeasures

Professor [REDACTED]

2026-05-03 23:59

Course Project: Part Two

This executive summary and report builds directly upon the threat evaluation completed in the previously completed Course Project: Part One. In the Course Project: Part One analysis, three Advanced Persistent Threat (APT) groups were identified as posing a significant risk to U.S. government, defense, and critical infrastructure environments based on confirmed activity occurring between 2022 and 2025 **(The MITRE Corporation, n.d.-b; The MITRE Corporation, n.d.-c; The MITRE Corporation, n.d.-d)**. Using the MITRE ATT&CK Framework, the previous analysis categorized adversary techniques by risk-level and identified the techniques requiring immediate attention and remediation **(The MITRE Corporation, n.d.-a)**. Based on that evaluation, this report focuses on five high-risk adversary techniques approved for immediate mitigation including:

- T1059: Command and Scripting Interpreter
- T1190: Exploit Public-Facing Application
- T1078: Valid Accounts
- T1083: File and Directory Discovery
- T1105: Ingress Tool Transfer

Per the guidelines set forth in the Course Project: Part Two requirements, this executive summary provides an overview of the ten NIST SP 800-53 Rev. 5 controls selected for immediate implementation, explains the rationale used to prioritize recommended controls in the Plan of Action and Milestones (POA&M) document, identifies issues and gaps discovered during the analysis, and provides recommendations for addressing organizational risk.

Overview of Selected High-Risk Adversary Techniques

The five high-risk adversary techniques selected present a realistic, dangerous attack path that can support initial compromise, credential abuse, internal reconnaissance, malicious execution, and follow-on payload delivery. These techniques were specifically chosen because they were strongly

associated with the selected APT groups and because they continue to be common methods utilized by modern threat actors to bypass traditional security controls while maintaining operational flexibility inside of target environments (**CrowdStrike, 2024; Mandiant, 2024**).

T1078: Valid Accounts

Valid Accounts (T1078) represents the highest-risk technique because it allows adversaries to use legitimate credentials to blend-in with normal user behavior in an effort to hide malicious activity. All three APT groups examined in Course Project: Part One rely on credential theft, compromised accounts, and abuse of existing privileges to reduce the likelihood of detection and maintain persistence (**The MITRE Corporation, n.d.-c; Microsoft Threat Intelligence, 2023, September 14**). According to the Verizon 2024 Data Breach Investigations Report, compromised credentials remain one of the most frequently observed vectors in confirmed security breaches (**Verizon, 2024**). This technique can be particularly dangerous since it can support lateral movement, privilege escalation, and continued access without requiring the obvious execution of malware (**CrowdStrike, 2024**).

T1059: Command and Scripting Interpreter

Command and Scripting Interpreter (T1059) also presents a high-risk threat because adversaries are able to use trusted, native tools such as PowerShell, Command Prompt, and Unix shell environments to execute malicious commands while avoiding the use of custom malware (**Microsoft Threat Intelligence, 2023**). This “Living off the Land” (LOTL) approach is particularly effective since organizations often lack the detection capabilities required to identify anomalous activities from legitimate administrative actions. This technique was consistently associated with the selected APT groups and remains one of the most effective methods for camouflaging malicious execution with expected administrative activity (**Picus Security, 2024**).

T1190: Exploit Public-Facing Application

Exploit Public-Facing Application (T1190) represents a major concern because internet-facing systems provide direct exposure to potentially hostile traffic and exploitation attempts. All it takes is a single unpatched vulnerability in a web application, VPN service, or externally accessible platform to provide threat actors with initial access to an enterprise environment **(Department of Justice, 2024)**. Since these systems serve as accessible entry points to the organization's systems, the risk associated with exploitation remains high even with more comprehensive defensive measures in place.

T1083: File and Directory Discovery

File and Directory Discovery (T1083) is a post-compromise technique that poses a high-risk because it allows threat actors to identify sensitive files, administrative scripts, configurations, and repositories after they have established access **(The MITRE Corporation, n.d.-a)**. Additionally, this technique supports follow-up actions such as credential harvesting, lateral movement, staging, and exfiltration. While it is often less visible than exploitation or malware deployment, it enables threat actors to identify high-value targets within the organization's environment.

T1105: Ingress Tool Transfer

Finally, Ingress Tool Transfer (T1105) presents an additional high-risk concern since it allows threat actors to download or transfer tools, scripts, and secondary payloads into the target compromised environment **(CISA, 2021)**. This technique expands the attacker's capabilities after initial access and increases the likelihood of persistence, privilege escalation, and long-term success. When utilized in combination with valid accounts or compromised public-facing systems, ingress tool transfer can significantly increase the severity of a breach **(Cybaverse, 2025)**.

Overview of the Selected NIST SP 800-53 Rev. 5 Controls

To mitigate the five approved high-risk adversarial techniques previously mentioned, a total of ten controls from NIST SP 800-53 Rev. 5 were selected and prioritized for immediate implementation in

the POA&M. These controls were specifically selected because they provide the greatest balance of mitigation coverage, defensive value, implementation feasibility, and alignment with the highest-risk techniques identified in the Course Project: Part One. The ten prioritized controls include:

1. CM-07: Least Functionality
2. SI-04: System Monitoring
3. CA-07: Continuous Monitoring
4. AC-06: Least Privilege
5. IA-02: Identification and Authentication (Organizational Users)
6. CM-06: Configuration Settings
7. SC-07: Boundary Protection
8. RA-05: Vulnerability Monitoring and Scanning
9. SI-03: Malicious Code Protection
10. AC-02: Account Management

These controls were selected because they create a layered, risk-based mitigation strategy instead of relying on a single category of protection. CM-07: Least Functionality was prioritized the highest because it reduces attack surface across all five techniques by limiting unnecessary services, applications, executables, interpreters, and system capabilities (**NIST, 2024**). Likewise, SI-04: System Monitoring and CA-07: Continuous Monitoring were also prioritized to the highest level since they improve visibility, support ongoing detection, and provide continuous awareness of control effectiveness and attacker activity (**The MITRE Corporation, n.d.-e**).

Furthermore, controls associated with identity and privilege management were also rated highly because of the risk posed by Valid Accounts (T1078). AC-06: Least Privilege, IA-02: Identification and Authentication (Organizational Users), and AC-02: Account Management were selected because they reduce the likelihood and potential impact of credential abuse by enforcing stronger authentication,

limiting unnecessary privileges, and improving account lifecycle management (**CrowdStrike, 2024**).

Additionally, CM-06: Configuration Settings was prioritized since it supports protection of public-facing services and helps control unauthorized communications that are often associated with exploitation and ingress tool transfer (**Department of Justice, 2024**). Finally, RA-05: Vulnerability Monitoring and Scanning and SI-03: Malicious Code Protection were also selected because vulnerability identification and malicious code protection are crucial to preventing exploitation and detecting transferred or executed payloads (**NIST, 2013**).

Methodology

The methodology used in the POA&M was based on four primary factors. First, controls that mitigated multiple high-risk adversarial techniques were assigned the highest priority because they provide the broadest coverage and provide the highest level of overall risk reduction. Controls such as CM-07: Least Privilege, SI-04: System Monitoring, and CA-07: Continuous Monitoring were ranked the highest since they support mitigation across all five of the selected techniques.

Second, the methodology provided additional weight on controls that addressed the highest-risk adversarial behavior first, particularly Valid Accounts (T1078). Since the Course Project: Part One analysis identified credential abuse as being among the most dangerous and difficult to detect techniques used by the selected APT groups. As such, controls that strengthen authentication, restrict privileges, and improve account oversight were prioritized accordingly (**CrowdStrike 2024; Verizon, 2024**).

Third, the POA&M accounted for control dependencies and implementation order. Controls that establish secure baseline conditions, improve visibility, or reduce the attack surface were prioritized before controls that depend on mature monitoring, hardened configurations, or established governance processes (**NIST, 2024**). Furthermore, this approach supports more effective implementation plans by

ensuring that baseline controls are in place before more specialized, targeted safeguards are put into place.

Fourth, the methodology balanced the difficulty of implementing controls against ones requiring longer-term implementation planning. Controls that were capable of producing immediate defensive improvement, including Least Functionality, Multi-Factor Authentication, Least Privilege, and System Monitoring, were assigned a higher priority since they provide an immediate, measurable benefit with an easy, short implementation time (**Mandiant, 2024**). While controls that require broader tuning, scanning maturity, or expanded coordination were still included in the top ten, the overall value they provide was considered against the time and difficulty to implement.

Issues, Gaps, and Residual Risk

An important issue we identified during this analysis was a gap in the ATT&CK to NIST control mapping was associated with File and Directory Discovery (T1083). In contrast to the other techniques selected, the mapping data did not clearly provide a standalone entry for File and Directory Discovery (T1083) in the same way. This presents a significant issue since it limits the completion of a spreadsheet-based approach to identifying controls (**The MITRE Corporation, n.d.-a**).

In an effort to address this issue, we conducted an additional review while keeping in mind the intention of NIST SP 800-53 Rev. 5 controls and overall cybersecurity best practices. Based on the additional review using MITRE D3FEND, we were able to determine that controls such as AC-06: Least Privilege, SI-04: System Monitoring, CM-06: Configuration Settings, AC-02: Account Management, and CA-07: Continuous Monitoring provide mitigation for File and Directory Discovery (T1083) by restricting attacker visibility of sensitive data and resources, reducing unnecessary functionality and services, and improving detection capabilities for suspicious enumeration behavior. The recommended approach for leadership moving forward is to consider the ATT&CK control mapping as a useful starting point, but not a complete replacement for manual analysis and risk-informed judgment (**The MITRE Corporation, n.d.**).

Furthermore, residual risk will remain after the implementation of the selected controls. Threat attackers displaying sophistication will still be able to exploit zero-day vulnerabilities, abuse trusted administrative tools, steal authenticated sessions, or perform reconnaissance with the intention of evading monitoring thresholds (**CrowdStrike, 2024; Mandiant, 2024**). Multi-factor authentication significantly reduces the risks associated with the abuse of valid accounts, but does not address threats involving token theft or sessions that have already been authenticated (**Cybaverse, 2025**). Likewise, while system monitoring improves visibility, it remains entirely dependent on proper logging, alert tuning, analyst review, and response maturity. It is for these reasons the controls recommended should be seen as a strong risk reduction strategy instead of being viewed as a guarantee of complete threat elimination.

Recommendations for Continued Risk Management

In an effort to support long-term risk reduction, the organization should maintain a continuous and threat-informed risk management process after the implementation of the recommended top ten controls. First, leadership should ensure and verify that the POA&M is reviewed and updated on a recurring continuing basis to ensure that implementation progress, unresolved weaknesses, and newly identified issues remain visible. Second, the organization should maintain strong continuous monitoring, vulnerability scanning, and detection engineering practices so that defensive coverage evolves with adversary tradecraft (**Mandiant, 2024**).

Third, leadership should support regular account reviews, privilege reviews, and authentication audits to reduce the long-term risk associated with Valid Accounts (T1083) (**CrowdStrike, 2024; Verizon, 2024**). Fourth, the organization should conduct periodic configuration audits and system hardening review to verify that secure baselines are maintained over time (**NIST, 2024**). Finally, when issues or gaps arise with ATT&CK to control mappings, they should be supplemented with manual control

analysis, updated threat intelligence, and additional research to avoid defensive blind spots (**The MITRE Corporation, n.d.-e**).

Conclusion

Concluding our executive summary, the five high-risk adversarial techniques identified during the analysis represent a serious, immediate threat to enterprise operations because they support unauthorized access, malicious execution, internal reconnaissance, exploitation of exposed services, and payload staging (**CISA/NSA, 2023; Microsoft Threat Intelligence, 2023 May 24**). The top ten NIST SP 800-53 Rev. 5 controls were prioritized in the POA&M because they provide the greatest combination of cross-technique mitigation, operational feasibility, and immediate defensive benefits (**NIST, 2013; NIST, 2024**). By implementing these controls in the provided order and maintaining continuous oversight of residual risks, the organization will be better positioned to reduce the impact of the selected adversarial techniques and improve resilience against APT activities in the evolving threat landscape (**CrowdStrike, 2024; Mandiant, 2024**).

References

- CISA. (2021, April 26). *Russian SVR Targets U.S. and Allied Networks* (AA21-116A). Retrieved from <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-116a>
- CISA/NSA. (2023, May 24). *PRC State-Sponsored Cyber Actor Living off the Land to Evade Detection* (AA23-144A). Retrieved from <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-144a>
- CrowdStrike. (2024). *Global Threat Report 2024*. Retrieved from <https://www.crowdstrike.com/en-us/resources/reports/crowdstrike-2024-global-threat-report/>
- Cybaverse. (2025). *The Rise of APT Groups Targeting EDR Protections in 2025*. Retrieved from <https://www.cybaverse.co.uk/resources/the-rise-of-apt-groups>
- Department of Justice. (2024, January 31). *FBI Disrupts Botnet People's Republic of China Used to Conceal Hacking of Critical Infrastructure*. Retrieved from <https://www.justice.gov/archives/opa/pr/us-government-disrupts-botnet-peoples-republic-china-used-conceal-hacking-critical>
- The MITRE Corporation (n.d. -a). *"Enterprise Techniques". Techniques - Enterprise | MITRE ATT&CK*. Retrieved from <https://attack.mitre.org/techniques/enterprise/>
- The MITRE Corporation (n.d. -b). *Volt Typhoon, Group G1017. MITRE ATT&CK*. Retrieved from <https://attack.mitre.org/groups/G1017/>
- The MITRE Corporation (n.d. -c). *APT29, Group G0016. MITRE ATT&CK*. Retrieved from <https://attack.mitre.org/groups/G0016/>
- The MITRE Corporation (n.d. -d). *APT33, Group G0064. MITRE ATT&CK*. Retrieved from <https://attack.mitre.org/groups/G0064/>
- The MITRE Corporation. (n.d. -e). *D3FEND: A knowledge graph of cybersecurity countermeasures*. Retrieved from <https://d3fend.mitre.org/>

Mandiant. (2024). *M-Trends 2024*. Retrieved from <https://cloud.google.com/security/resources/m-trends>

Microsoft Threat Intelligence. (2023, May 24). *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*. Retrieved from <https://www.microsoft.com/en-us/security/blog/2023/05/24/volt-typhoon-targets-us-critical-infrastructure-with-living-off-the-land-techniques/>

Microsoft Threat Intelligence. (2023, September 14). *Peach Sandstorm password spray campaigns enable intelligence collection at high-value targets*. Retrieved from <https://www.microsoft.com/en-us/security/blog/2023/09/14/peach-sandstorm-password-spray-campaigns-enable-intelligence-collection-at-high-value-targets/>

NIST. (2013). *Guide to Malware Incident Prevention and Handling* (SP 800-83 Rev. 1). Retrieved from <https://csrc.nist.gov/pubs/sp/800/83/r1/final>

NIST. (2024). *Guide to Application Whitelisting* (SP 800-167). Retrieved from <https://csrc.nist.gov/pubs/sp/800/167/final>

Picus Security. (2024). *Volt Typhoon Explained: Living Off the Land Tactics for Cyber Espionage*. Retrieved from <https://www.picussecurity.com/resource/blog/volt-typhoon-living-off-the-land-cyber-espionage>

Verizon. (2024). *2024 Data Breach Investigations Report*. Retrieved from <https://www.verizon.com/business/resources/reports/2025-dbir-data-breach-investigations-report.pdf>